

PLANTILLA DE EXCEL: CÁLCULO IGM-DREAD Y ROI DE CIBERSEGURIDAD

Especificación técnica completa para implementación inmediata

Kit GQM+PRAGMATIC • Hoja de Cálculo • Edición 2025-2026

"Excel no resuelve los problemas de ciberseguridad, pero sí revela con cruel claridad cuáles son. Y a veces, eso es exactamente lo que el comité de dirección necesita ver."

VISIÓN GENERAL DEL LIBRO DE CÁLCULO

Nombre del fichero recomendado: IGM_DREAD_GQM_PRAGMATIC_v1.0_[ORGANIZACIÓN]_[AÑO].xlsx

Número de hojas: 9

Tecnología: Microsoft Excel 2019+ / Google Sheets / LibreOffice Calc

Usuarios objetivo: CISO, Analista de Riesgos, Gestor de Vulnerabilidades, CFO (hoja ROI)

DESCRIPCIÓN DE LAS 9 HOJAS

HOJA 1: INICIO — Portada e instrucciones de uso

Propósito: Portada del libro de cálculo con metadatos del análisis e instrucciones de navegación.

Campos obligatorios a cumplimentar:

Campo	Descripción	Ejemplo
Organización	Nombre completo de la entidad analizada	ACME S.A.
CIF	Identificador fiscal	B12345678
Sector NIS2	Sector según clasificación NIS2/LCGC-2025	Energía (Anexo I)
Clasificación ENS	Nivel de clasificación ENS aplicable	Alto / Medio / Básico
CISO responsable	Nombre y cargo del responsable del análisis	Juan García, CISO
Fecha de análisis	Fecha de inicio del análisis	2026-04-08
Período analizado	Período de referencia de los datos	Q1 2026 (ene-mar 2026)
Versión del kit	Versión del marco GQM+PRAGMATIC	v1.0
Siguiente revisión	Fecha prevista de la próxima actualización	2026-07-08

Instrucciones de navegación: Cada hoja tiene una pestaña codificada por color:

- ● Rojo: Hojas de entrada de datos (requieren cumplimentación manual)
- ● Amarillo: Hojas de cálculo automático (no editar fórmulas sin autorización)

- Verde: Hojas de resultados y reportes (solo lectura)
- Azul: Hojas de configuración y parámetros (editar con precaución)

HOJA 2: DATOS_ENCUESTA — Entrada de datos de la encuesta organizativa

Propósito: Registro de las respuestas cuantitativas obtenidas de la encuesta a responsables de seguridad.

Estructura de la tabla (columnas A–R):

A: ID_Pregunta	→ Identificador de la pregunta de la encuesta (P01–P60)
B: Dimensión_DREAD	→ D / R / E / A / Disc
C: ID_Métrica_GQM	→ D.M1, R.M1, E.M2, etc.
D: Nombre_Métrica	→ Nombre completo de la métrica
E: Valor_Actual	→ Valor reportado por la organización (número)
F: Unidad	→ %, €, días, horas, número, ratio
G: Fecha_Medición	→ Fecha de la última medición (AAAA-MM-DD)
H: Fuente_Dato	→ Sistema origen (SIEM, VM tool, ITSM, manual, etc.)
I: Confianza_Dato	→ 1=Baja / 2=Media / 3=Alta (evaluación del analista)
J: Umbral_Objetivo	→ Valor objetivo establecido por la organización
K: Umbral_Alerta	→ Valor de alerta (entre objetivo y crítico)
L: Umbral_Critico	→ Valor de criticidad según norma aplicable
M: Estado_Semáforo	→ Fórmula automática: VERDE/AMARILLO/ROJO
N: Norma_Principal	→ Marco normativo de referencia (NIS2/ENS/DORA/GDPR)
O: Score_DREAD_Dim	→ Puntuación DREAD para esta dimensión (1-10)
P: Score_PRAGMATIC	→ Puntuación PRAGMATIC de la métrica (0-90)
Q: Peso_IGM	→ Peso de la métrica en el IGM global (suma = 100%)
R: Notas	→ Observaciones del analista, limitaciones, excepciones

Reglas de validación:

- Columna E: Solo números (no texto). Si el dato no está disponible, usar -1 y documentar en columna R.
- Columna I: Lista desplegable: 1=Baja, 2=Media, 3=Alta.
- Columna M: Fórmula automática basada en comparación con umbrales:

$$=SI(E2 \leq J2, " \text{Verde} ", SI(E2 \leq K2, " \text{Amarillo} ", " \text{Rojo} "))$$
 (Nota: La dirección de la comparación se invierte para métricas donde "mayor = mejor", como ICCAE o CCUC)
- Columna Q: Los pesos deben sumar 100%. Se proporciona una fila de verificación con la fórmula

$$=SUMA(Q2:Q24).$$

Tabla de pesos por defecto (IGM estándar):

Dimensión DREAD	Peso dimensión	Distribución interna sugerida
D — Daño	30%	D.M1(8%)+D.M2(5%) +D.M3(9%)+D.M4(4%) +D.M5(4%)
R — Reproducibilidad	20%	R.M1(7%)+R.M2(7%) +R.M3(3%)+R.M4(3%)
E — Explotabilidad	20%	E.M1(3%)+E.M2(8%) +E.M3(2%)+E.M4(4%) +E.M5(3%)
A — Usuarios Afectados	20%	A.M1(6%)+A.M2(3%) +A.M3(5%)+A.M4(3%) +A.M5(3%)
Disc — Descubribilidad	10%	Disc.M1(3%)+Disc.M2(3%) +Disc.M3(2%)+Disc.M4(2%)
TOTAL	100%	

HOJA 3: IGM_POR_DIMENSIÓN — Cálculo del Índice de Gestión de Métricas por dimensión DREAD

Propósito: Cálculo automático del IGM para cada una de las cinco dimensiones DREAD.

Estructura de cálculo para cada dimensión:

Para cada dimensión D, R, E, A, Disc se calcula:

$$IGM_Dim = \Sigma(\text{Valor_Normalizado}_i \times \text{Peso}_i) / \Sigma(\text{Peso}_i)$$

Donde:

$$\text{Valor_Normalizado}_i = (\text{Valor_Actual}_i - \text{Umbral_Crítico}_i) / (\text{Umbral_Objetivo}_i - \text{Umbral_Crítico}_i)$$

$$\text{Valor_Normalizado}_i = \text{MAX}(0, \text{MIN}(1, \text{Valor_Normalizado}_i)) \quad \leftarrow \text{Clamping } 0-1$$

Tabla de visualización por dimensión:

Dimensión	IGM_Dim (0-100)	Nivel de madurez	Estado	Tendencia
D — Daño	[fórmula]	[semáforo]	[texto]	[flecha]
R — Reproducibilidad	[fórmula]	[semáforo]	[texto]	[flecha]
E — Explotabilidad	[fórmula]	[semáforo]	[texto]	[flecha]
A — Usuarios Afectados	[fórmula]	[semáforo]	[texto]	[flecha]
Disc — Descubribilidad	[fórmula]	[semáforo]	[texto]	[flecha]

Escala de madurez IGM_Dim:

- 85–100: Madurez Optimizada (Nivel 5)
- 70–84: Madurez Gestionada (Nivel 4)
- 55–69: Madurez Definida (Nivel 3)
- 40–54: Madurez en Desarrollo (Nivel 2)
- < 40: Madurez Inicial (Nivel 1)

Gráfico radar automático: Esta hoja incluye un gráfico radar (tipo spider) con los 5 valores IGM_Dim, que visualiza el perfil de madurez DREAD de la organización. El gráfico muestra también el valor benchmark sectorial (si está disponible en HOJA 7).

HOJA 4: IGM_GLOBAL — Cálculo del IGM Global Ponderado

Propósito: Cálculo del Índice de Gestión de Métricas (IGM) global de la organización y comparativa con benchmarks.

Fórmula IGM Global:

$$\begin{aligned}\text{IGM_Global} &= \sum(\text{IGM_Dim}_i \times \text{Peso_Dim}_i) \\ &= \text{IGM_D} \times 0.30 + \text{IGM_R} \times 0.20 + \text{IGM_E} \times 0.20 + \text{IGM_A} \times 0.20 + \text{IGM_Disc} \times 0.10\end{aligned}$$

Panel principal de la hoja:

IGM GLOBAL DREAD	
[Valor IGM_Global] / 100	
[Nivel de Madurez]	[Color semáforo]
Benchmark sector: [valor de HOJA 7]	
Desviación vs. benchmark: [IGM_Global - Benchmark]	
Percentil sectorial estimado: [cálculo]	

Presets sectoriales de pesos (seleccionables desde lista desplegable):

Sector	Peso_D	Peso_R	Peso_E	Peso_A	Peso_Disc	Justificación
Estándar (default)	30%	20%	20%	20%	10%	Marco base GQM-DREAD
Energía/Utilities	35%	15%	15%	25%	10%	Impacto masivo ciudadanos, OT/ICS
Sector Financiero (DORA)	25%	20%	20%	15%	20%	Descubribilidad crítica, DORA compliance
Sanidad/Hospitales	30%	20%	20%	25%	5%	Datos Art.9 GDPR + vidas humanas
Administración Pública (ENS)	30%	20%	20%	20%	10%	ENS mandatorio + ciudadanos como usuarios
Manufactura/OT (IEC 62443)	35%	15%	20%	15%	15%	Explotabilidad OT/ICS elevada
Telecomunicaciones	25%	25%	20%	20%	10%	Reproducibilidad alta en redes masivas

Tabla de evolución temporal:

Período	IGM_Global	IGM_D	IGM_R	IGM_E	IGM_A	IGM_Disc	Δ vs. anterior
Q4 2025	[manual]	[m]	[m]	[m]	[m]	[m]	—
Q1 2026	[auto]	[auto]	[auto]	[auto]	[auto]	[auto]	[fórmula]
Q2 2026	[vacío]	...	...	...	...	...	—

HOJA 5: BENCHMARKING — Comparativa sectorial y geográfica

Propósito: Posicionamiento de la organización respecto a benchmarks sectoriales, nacionales e internacionales.

Fuentes de benchmark disponibles:

- INCIBE: Informe de Ciberseguridad en España 2025

- ENISA: NIS Investments Report 2025
- IBM/Ponemon: Cost of a Data Breach Report 2025
- Dragos: OT/ICS Cybersecurity Year in Review 2025
- Verizon DBIR 2025

Tabla de comparativa:

Métrica	Valor organización	Benchmark España	Benchmark UE	Benchmark Global	Percentil España
MTTR (R.M1) [días]	[org]	[INCIBE]	[ENISA]	[Verizon]	[fórmula]
TVER EPSS>0.5 (R.M2) [%]	[org]	—	[ENISA]	—	—
TMCE (E.M4) [horas]	[org]	[INCIBE]	—	[IBM]	[fórmula]
ALE/ facturación (D.M1) [%]	[org]	—	—	[IBM]	—
CUA (A.M4) [€/usuario]	[org]	—	[ENISA]	[IBM/Ponemon]	[fórmula]

Instrucciones: Los valores de benchmark deben actualizarse manualmente al inicio de cada año con los datos de los informes anuales de referencia. Las celdas de benchmark están resaltadas en azul claro y protegidas con contraseña de hoja para evitar edición accidental.

HOJA 6: MODELO_ROI — Cálculo de ROI de la Inversión en Ciberseguridad

Propósito: Justificación económica de las inversiones en ciberseguridad utilizando las métricas DREAD como base.

Sección 1: Parámetros de entrada (celdas editables en amarillo)

Parámetro	Valor	Fuente/Justificación
Facturación anual organización (€)	[INPUT]	Informe anual / CCAA
ALE actual (€/año) — antes de inversión	[=D.M1 actual]	HOJA 2
ALE proyectado (€/año) — tras inversión	[INPUT]	Estimación del analista
Inversión total en ciberseguridad (€)	[INPUT]	Presupuesto aprobado
Período de análisis (años)	[INPUT]	Típicamente 3–5 años
Tasa de descuento (WACC o RF)	[INPUT]	Área financiera
Coste operativo anual de las medidas (€)	[INPUT]	Estimación del analista

Sección 2: Cálculo ALE y ROSI

$\text{Reducción_ALE} = \text{ALE_actual} - \text{ALE_proyectado}$

$\text{ROSI} = (\text{Reducción_ALE} - \text{Coste_operativo_anual}) / \text{Inversión_total} \times 100 \quad [\%]$

$\text{ROSI_NETO} = \text{Reducción_ALE} - \text{Coste_operativo_anual} - (\text{Inversión_total} / \text{Período_análisis})$

Sección 3: Análisis NPV y Payback

$\text{FCF_año_n} = \text{Reducción_ALE} - \text{Coste_operativo_anual}$

$\text{VAN} = -\text{Inversión} + \sum (\text{FCF_n} / (1 + \text{Tasa_descuento})^n)$ para $n = 1$ a Período

$\text{Payback_años} = \text{Inversión} / \text{FCF_anual_medio}$

$\text{TIR} = [\text{función IRR de Excel sobre flujos de caja}]$

Sección 4: Análisis de sensibilidad (tabla bidimensional)

Tabla cruzada de ROSI bajo distintos escenarios de:

- Reducción ALE: 20%, 30%, 40%, 50%, 60%
- Coste total inversión: 50K€, 100K€, 200K€, 500K€, 1M€

La tabla es generada automáticamente mediante la función de tabla de datos bidimensional de Excel.

Sección 5: Justificación ante el Consejo de Administración

Texto automático generado por fórmulas de texto concatenado:

"La inversión de [€ inversión] en [mejoras identificadas] reduce la pérdida anual esperada de [ALE_actual] € a [ALE_proyectado] €, lo que supone un ahorro neto anual de [reducción_ALE] € y un ROI del [ROSI]% en [período] años. El Payback estimado es de [payback] meses."

HOJA 7: SCORING_AMENAZAS — Matriz de puntuación DREAD por amenaza

Propósito: Herramienta de puntuación DREAD para amenazas específicas identificadas por el equipo de seguridad.

Estructura de la tabla:

A: ID_Amenaza	→ Identificador único (AMZ-001, AMZ-002...)
B: Nombre_Amenaza	→ Descripción breve de la amenaza
C: CVE/ID_Externo	→ Identificador externo si aplica
D: Fecha_Identificación	→ Fecha de identificación
E: Score_D	→ Puntuación Daño (1-10)
F: Score_R	→ Puntuación Reproducibilidad (1-10)
G: Score_E	→ Puntuación Explotabilidad (1-10)
H: Score_A	→ Puntuación Usuarios Afectados (1-10)
I: Score_Disc	→ Puntuación Descubribilidad (1-10)
J: DREAD_Score_Avg	→ =PROMEDIO(E:I) – Score DREAD promedio
K: DREAD_Score_W	→ Score ponderado con pesos sectoriales de HOJA 4
L: Prioridad	→ SI(K2>=8, "CRÍTICA", SI(K2>=6, "ALTA", SI(K2>=4, "MEDIA", "BAJA")))
M: EPSS_Score	→ Valor EPSS actual (introducir manualmente desde FIRST.org)
N: En_CISA_KEV	→ SÍ/NO (verificación manual o automatizada)
O: CVSS_Score	→ Score CVSS v3.1/v4.0 desde NVD
P: Score_Compuesto	→ =(K2*0.5)+(M2*10*0.3)+(SI(N2="SÍ",10,0)*0.2) – Prioritización combinada
Q: Estado_Remediación	→ PENDIENTE / EN_PROGRESO / COMPLETADO / ACEPTADO
R: Propietario	→ Responsable de la remediación
S: Fecha_Objeto	→ Fecha límite de remediación
T: Notas	→ Observaciones adicionales

Fórmula de priorización compuesta (columna P):

$$\text{Score_Compuesto} = (\text{DREAD_Weighted} \times 0.50) + (\text{EPSS} \times 10 \times 0.30) + (\text{KEV_Flag} \times 10 \times 0.20)$$

Esta fórmula combina la valoración interna DREAD (50%), la probabilidad de explotación EPSS (30%) y la presencia en CISA KEV (20%), alineándose con las recomendaciones de KCYERRID (2026) sobre combinación de métodos de priorización.

Filtros y ordenación automática:

- Botón "Ordenar por Score_Compuesto DESC": ordena la tabla por prioridad de remediación
- Filtro "Solo KEV activos": muestra únicamente las amenazas presentes en CISA KEV
- Filtro "Solo EPSS > 0.5": muestra amenazas con alta probabilidad de explotación

HOJA 8: DASHBOARD_EJECUTIVO — Panel visual para presentación al Consejo

Propósito: Vista consolidada de todos los indicadores clave para presentación a la alta dirección.

Distribución visual de la hoja (no imprimible, para pantalla):

IGM GLOBAL [Gauge chart] XX.X / 100	TOP 3 RIESGOS CRÍTICOS [lista KEV]	TENDENCIA IGM [Line chart] (últimos 4 Q)
RADAR DREAD [Spider chart] D-R-E-A-Disc	SEMÁFORO 23 MÉTRICAS [tabla color]	ROI INVERSIÓN ROSI: XX% Payback: Xm
CUMPLIMIENTO NORMATIVO NIS2/DORA/GDPR	VULNERABILIDADES CRÍTICAS SIN REMIAR	ACCIÓN REQUERI- DA: TOP 5 GAPS [lista accion.]

Configuración de gráficos:

1. Gauge IGM Global: Gráfico de velocímetro (implementado con gráfico de roscas semicircular). Colores: rojo 0-40, naranja 40-55, amarillo 55-70, verde claro 70-85, verde oscuro 85-100.
2. Radar DREAD: Gráfico de araña con 5 ejes (D, R, E, A, Disc). Muestra dos series: (a) Valor actual de la organización y (b) Benchmark sectorial (de HOJA 5).
3. Línea de tendencia IGM: Gráfico de línea con los valores históricos de IGM_Global (de HOJA 4). Incluye línea de tendencia lineal con proyección a próximo período.
4. Semáforo de 23 métricas: Tabla compacta con una celda por métrica coloreada en verde/amarillo/rojo según el estado calculado en HOJA 2.

Gauge IGM Global: Gráfico de velocímetro (implementado con gráfico de roscas semicircular). Colores: rojo 0-40, naranja 40-55, amarillo 55-70, verde claro 70-85, verde oscuro 85-100.

Radar DREAD: Gráfico de araña con 5 ejes (D, R, E, A, Disc). Muestra dos series: (a) Valor actual de la organización y (b) Benchmark sectorial (de HOJA 5).

Línea de tendencia IGM: Gráfico de línea con los valores históricos de IGM_Global (de HOJA 4). Incluye línea de tendencia lineal con proyección a próximo período.

Semáforo de 23 métricas: Tabla compacta con una celda por métrica coloreada en verde/amarillo/rojo según el estado calculado en HOJA 2.

HOJA 9: CONFIGURACIÓN — Parámetros globales y tablas de referencia

Propósito: Centralización de todos los parámetros y tablas de referencia utilizados en las demás hojas.

Sección A: Umbrales normativos de referencia

Tabla de umbrales por métrica extraída de los requisitos NIS2, ENS, DORA y GDPR. Estos valores se utilizan como umbrales por defecto en HOJA 2 y pueden ser personalizados por la organización con justificación documentada.

Sección B: Pesos sectoriales

Tabla completa de pesos por sector (la misma que en HOJA 4) para referencia y modificación.

Sección C: Tabla de correspondencia métricas-normas

Resumen compacto del Documento D (Mapeo Normativo) en formato tabla Excel.

Sección D: Registro de versiones del libro

Versión	Fecha	Autor	Cambios realizados
1.0	2026-04-08	[CISO]	Versión inicial
1.1	[fecha]	[nombre]	[descripción]

Sección E: Glosario de términos

Tabla de definiciones para los términos técnicos usados en el libro, accesible mediante hipervínculos desde las celdas de encabezado de otras hojas.

INSTRUCCIONES DE IMPLEMENTACIÓN

Paso 1: Preparación (semana 1)

5. Descargar la plantilla desde el repositorio del kit
6. Cumplimentar la HOJA 1 (INICIO) con los metadatos de la organización
7. Revisar y ajustar los umbrales de la HOJA 9 (CONFIGURACIÓN) al contexto organizativo
8. Seleccionar el preset sectorial de pesos en HOJA 4

Paso 2: Recogida de datos (semanas 2-4)

9. Completar la HOJA 2 (DATOS_ENCUESTA) con los valores actuales de cada métrica
10. Para cada valor, documentar la fuente y el nivel de confianza (columna I)
11. Si un dato no está disponible, registrar -1 en columna E y documentar en columna R
12. Completar la HOJA 7 (SCORING_AMENAZAS) con las amenazas identificadas

Paso 3: Análisis y validación (semana 5)

13. Revisar los resultados automáticos de HOJA 3 (IGM por dimensión)
14. Verificar el IGM Global en HOJA 4 y comparar con benchmarks de HOJA 5
15. Completar los parámetros del modelo ROI en HOJA 6
16. Revisar el DASHBOARD_EJECUTIVO de HOJA 8

Paso 4: Reporting (semana 6)

17. Exportar el DASHBOARD_EJECUTIVO (HOJA 8) como PDF para presentación al Consejo
18. Exportar la tabla de amenazas prioritarias de HOJA 7 para el equipo técnico
19. Documentar el plan de acción para las métricas en estado ROJO
20. Programar la próxima revisión (trimestral recomendado para métricas operativas)

AUTOMATIZACIÓN AVANZADA (OPCIONAL)

Para organizaciones con capacidad de automatización, se recomienda:

Integración con APIs externas (mediante Power Query o Python/VBA):

- FIRST EPSS API: <https://api.first.org/data/v1/epss?cve=CVE-XXXX-XXXX>
- CISA KEV API:
https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json
- NVD API v2.0: <https://services.nvd.nist.gov/rest/json/cves/2.0>

Script Power Query para actualización diaria de EPSS y KEV:

```
// Conexión a CISA KEV
let
    Source = Json.Document(Web.Contents("https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json")),
    Vulnerabilities = Source[vulnerabilities],
    Table = Table.FromList(Vulnerabilities, Splitter.SplitByNothing(), null, null, ExtraValues.Error),
    ExpandedColumns = Table.ExpandRecordColumn(Table, "Column1", {"cveID", "vendorProject", "product", "vulnerabilityName", "dateAdded", "shortDescription", "requiredAction", "dueDate"})
in
    ExpandedColumns
```

Plantilla Excel IGM-DREAD · Documento E del Kit GQM+PRAGMATIC · Abril 2026

Metodología: FAIR Institute, INCIBE-IMC, NIST SP 800-55, Brothby & Hinson (2013)